

Guide pratique de sécurisation du serveur web Apache

1. Installation d'Apache

```
# Installer Apache
sudo apt update
sudo apt install apache2 -y

# Vérifier le statut d'Apache
sudo systemctl status apache2
```

Par défaut, l'installation d'Apache crée une configuration fonctionnelle mais pas nécessairement sécurisée. La suite de ce guide vous permettra d'appliquer les bonnes pratiques de sécurité.

2. Mesures de sécurité génériques

Apache fonctionne grâce à un ensemble de modules.

Commencez par désactiver les modules non nécessaires et activer les modules permettant de sécuriser notre serveur Apache.

```
# Désactiver les modules non nécessaires
sudo a2dismod status autoindex -f

# Activer les modules de sécurité essentiels
sudo a2enmod ssl headers rewrite

# Cacher les informations du serveur
sudo nano /etc/apache2/conf-enabled/security.conf
```

Dans le fichier `security.conf`, ajoutez ou modifiez les directives suivantes :

```
# Cacher la version et les informations du serveur
ServerTokens Prod
ServerSignature Off

# Désactiver les requêtes TRACE
TraceEnable Off
# Protéger contre les attaques clickjacking et XSS
Header always append X-Frame-Options SAMEORIGIN
```

Header always set X-XSS-Protection "1; mode=block"

Header always set X-Content-Type-Options nosniff

- ServerTokens Prod : Limite les informations transmises dans les en-têtes HTTP à simplement "Apache" sans version. Sans faire cela, un attaquant pourrait vérifier si notre version d'apache possède une vulnérabilité connue et essayer de l'exploiter.
- ServerSignature Off : Supprime la signature d'Apache dans les pages d'erreur générées
- TraceEnable Off : Désactive la méthode HTTP TRACE qui peut être utilisée pour des attaques XST (Cross-Site Tracing)
- X-Frame-Options SAMEORIGIN : Empêche votre site d'être intégré dans des iframes sur d'autres domaines (protection contre le clickjacking)
- X-XSS-Protection : Active la protection contre les attaques XSS dans les navigateurs modernes
- X-Content-Type-Options : Empêche le "MIME-sniffing" des ressources vers un type MIME différent

3. Mesures de sécurité dans les Virtual Hosts Pour l'extranet (public)

Forcer l'utilisation de HTTPS

<VirtualHost *:80>

ServerName extranet.valserac.com

RewriteEngine On

RewriteRule ^(.*)\$ https://%{HTTP_HOST}\$1 [R=301,L]

</VirtualHost>

Configuration SSL

<VirtualHost *:443>

Configuration SSL sécurisée

SSLEngine on

SSLCertificateFile /etc/apache2/ssl/extranet.crt

SSLCertificateKeyFile /etc/apache2/ssl/extranet.key

Protocoles SSL sécurisés

SSLProtocol all -SSLv2 -SSLv3 -TLSv1 -TLSv1.1

SSLCipherSuite

EECDH+AESGCM:EDH+AESGCM:AES256+EECDH:AES256+EDH

SSLHonorCipherOrder on

En-têtes de sécurité

```
Header always set Strict-Transport-Security "max-age=63072000;  
includeSubDomains; preload"
```

```
# Désactiver le listage des répertoires  
<Directory /var/www/extranet>  
    Options -Indexes -FollowSymLinks  
    AllowOverride None  
    Require all granted  
</Directory>  
</VirtualHost>
```

- La redirection HTTP vers HTTPS est impérative pour la sécurité
- -SSLv2 -SSLv3 -TLSv1 -TLSv1.1 : Désactive les protocoles SSL/TLS obsolètes et vulnérables
- SSLCipherSuite : Définit les suites de chiffrement préférées, privilégiant les plus sécurisées
- SSLHonorCipherOrder on : Utilise l'ordre des suites de chiffrement défini par le serveur
- HSTS (HTTP Strict Transport Security) : Force les clients à utiliser HTTPS pendant une période prolongée
- Options -Indexes : Empêche l'affichage automatique du contenu des répertoires
- Options -FollowSymLinks : Empêche Apache de suivre les liens symboliques

4. Changement des ports par défaut

Ensuite, il est nécessaire de changer les ports d'écoute.

```
# Modifier la configuration pour l'intranet  
sudo nano /etc/apache2/sites-available/intranet.conf
```

Dans le fichier de configuration, utilisez :

```
# Configuration de l'intranet sur des ports non standards  
<VirtualHost *:5501>  
    # Configuration HTTP  
</VirtualHost>  
  
<VirtualHost *:5502>  
    # Configuration HTTPS  
    SSLEngine on  
</VirtualHost>
```

Puis activez l'écoute sur ces ports :

```
# Ajouter l'écoute sur les ports personnalisés
echo "Listen 5501" | sudo tee -a /etc/apache2/ports.conf
echo "Listen 5502" | sudo tee -a /etc/apache2/ports.conf
```

- Le changement de ports réduit la découverte automatisée du service par des scans standards
- Les ports 80/443 sont généralement les premiers ciblés par des attaques automatisées
L'utilisation de ports non standards pour l'intranet ajoute une couche de sécurité par obscurité
- Cette mesure ne remplace pas une vraie sécurité, mais complète votre stratégie de défense en profondeur
- Les ports personnalisés (5501/5502) sont au-dessus de 1024, permettant à Apache de les utiliser sans privilèges root

5. Configuration des droits pour le dossier PDF

```
# Modifier le propriétaire et le groupe du répertoire
sudo chown www-data:www-data /var/www/extranet/pdf

# Définir les permissions appropriées
sudo chmod 750 /var/www/extranet/PDF
```

- `chown www-data:www-data` : Attribue la propriété au compte utilisateur et groupe utilisé par Apache
- Cela permet à Apache d'écrire dans ce répertoire sans donner de droits excessifs
`www-data` est le compte standard utilisé par Apache sur Debian/Ubuntu
`chmod 750` signifie :
 - 7 pour le propriétaire (`www-data`) : lecture (4) + écriture (2) + exécution (1)
 - Lecture : capacité à lister le contenu des fichiers
 - Écriture : capacité à modifier ou créer des fichiers
 - Exécution : capacité à accéder au contenu du répertoire
 - 5 pour le groupe (`www-data`) : lecture (4) + exécution (1)
- Les membres du groupe peuvent lire les fichiers et naviguer dans le répertoire 0 pour les autres : aucun droit
- Les utilisateurs qui ne sont ni propriétaire ni membre du groupe n'ont aucun accès

Cette configuration permet à Apache d'ajouter et de modifier des documents PDF dans ce répertoire en maintenant un niveau de sécurité approprié en empêchant les autres utilisateurs d'y accéder.

6. Gestion des droits pour les groupes développeurs et graphistes

Créer les groupes

```
sudo groupadd dev
```

```
sudo groupadd graph
```

Créer les utilisateurs de test

```
sudo useradd -m -G dev testdev
```

```
sudo useradd -m -G graph testgraph
```

```
sudo passwd testdev
```

```
sudo passwd testgraph
```

Configuration pour les développeurs (accès complet aux sources) `sudo chown -R`

```
www-data:dev /var/www/extranet
```

```
sudo chown -R www-data:dev /var/www/intranet
```

```
sudo chmod -R 750 /var/www/extranet
```

```
sudo chmod -R 750 /var/www/intranet
```

Cas particulier pour le dossier PDF

```
sudo chown -R www-data:www-data /var/www/extranet/pdf
```

```
sudo chmod 750 /var/www/extranet/pdf
```

Configuration pour les graphistes (accès aux images uniquement) `sudo chown -R`

```
www-data:graph /var/www/extranet/images
```

```
sudo chown -R www-data:graph /var/www/intranet/images
```

```
sudo chmod -R 750 /var/www/extranet/images
```

```
sudo chmod -R 750 /var/www/intranet/images
```

1. Création des groupes et utilisateurs

Nous créons deux groupes distincts : `developers` et `designers`

Les utilisateurs de test sont créés et assignés à leur groupe respectif

Le paramètre `-m` crée automatiquement un répertoire `home` pour chaque utilisateur

2. Configuration des droits pour les développeurs

Le propriétaire reste `www-data` pour qu'Apache puisse servir les fichiers Le groupe est défini comme `developers` pour permettre aux développeurs d'accéder aux fichiers

Les permissions `750` donnent :

- Contrôle total au propriétaire (Apache)

- Lecture et navigation aux développeurs

Aucun accès aux autres utilisateurs

3. Configuration spéciale pour le dossier PDF

Le dossier PDF conserve ses droits spécifiques pour permettre à Apache d'y écrire

Les développeurs n'ont pas accès direct à ce dossier via le groupe

4. Configuration pour les graphistes

Les graphistes ont accès uniquement aux répertoires d'images

Les permissions sont configurées pour leur permettre de modifier les fichiers d'images

Cette séparation des droits applique le principe du moindre privilège

Cette configuration crée une séparation claire des rôles et respecte le principe de sécurité du moindre privilège : chaque utilisateur n'a accès qu'aux ressources strictement nécessaires à son travail.